



Vulnerabilidades en Sistemas de Escritorio

Conde Ramos Jose Lucino

Gonzalez Cruz Maritza

Guzman Ojeda Brayan Uriel

Jimenez Torres Usvaldo

Que es?

Las vulnerabilidades del sistema operativo se refieren a fallas dentro del software de un sistema operativo que pueden ser explotadas por atacantes para comprometer la seguridad, integridad o funcionalidad de un sistema informático.

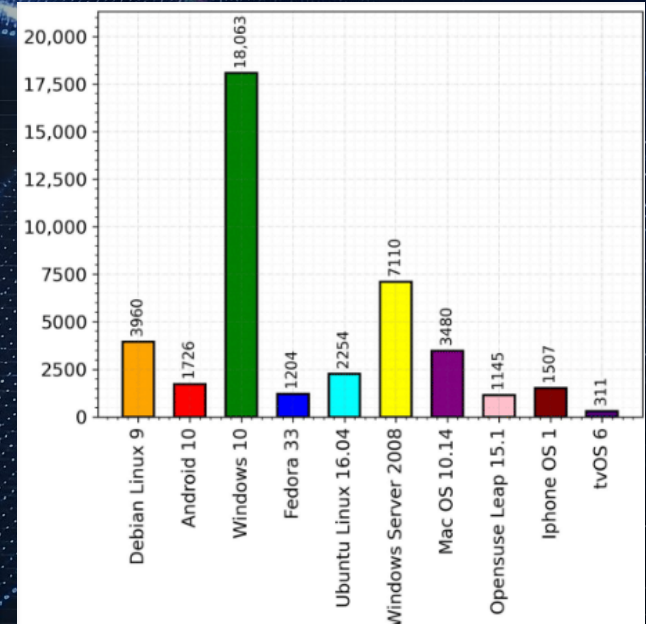
Estas vulnerabilidades pueden provenir de diversas fuentes, incluidos errores de diseño, funciones de seguridad inadecuadas o errores de programación. Crean oportunidades para el acceso no autorizado o actividades maliciosas como robo de datos, daños al sistema e interrupción de servicios.



Que S.O tiene mas vulnerabilidades?

Bhurtel y Rawat (2023) realizó un análisis de vulnerabilidades conocidas en sistemas operativos comunes. Su estudio consideró el número de vulnerabilidades encontradas en cada sistema operativo entre los años 1999-2022, según la Enumeración de Debilidad Común (CWE), y su gravedad según el Sistema de Puntuación de Vulnerabilidad Común (CVSS).

Bhurtel, M., & Rawat, D. B. (2023). Unveiling the landscape of operating system vulnerabilities. *Future Internet*, 15(7), 248. <https://doi.org/10.3390/fi15070248>



Tipos de Vulnerabilidades

01

Desbordamiento de búfer (Buffer Overflow)

Ocurre cuando un programa escribe más información de la que una región de memoria puede almacenar, permitiendo corrupción de memoria y posible ejecución de código malicioso.

02

Escalada de privilegios

Permite que un usuario obtenga permisos superiores a los autorizados, llegando incluso a privilegios de administrador o root.

03

Vulnerabilidades de secuencias de comandos entre sitios (XSS):

Ocurren cuando un sitio web permite la entrada de datos de usuarios y los incluye en una página web sin validarlos ni codificarlos. Esto permite a los atacantes inyectar y ejecutar scripts maliciosos (generalmente JavaScript) en el navegador de otros usuarios

04

Ejecución remota de código (RCE)

Permite ejecutar instrucciones en un equipo sin acceso físico mediante la explotación de fallos en servicios o aplicaciones.

Tipos de Vulnerabilidades

05

DLL Hijacking

Consiste en cargar una biblioteca dinámica maliciosa en lugar de la legítima para ejecutar código no autorizado, el secuestro de DLL engaña a un sistema operativo para que ejecute un binario malicioso en lugar de una DLL legítima.

06

Autorización incorrecta

Se produce cuando los permisos permiten acciones que deberían estar restringidas.

07

Vulnerabilidades Zero-Day

- Es un tipo de vulnerabilidad que acaba de ser descubierta y que aun no tiene un parche que la solucione. La principal amenaza reside en que, hasta que se lanza dicho parche correctivo y los usuarios lo instalan en sus equipos, los atacantes tienen vía libre para explotar la vulnerabilidad y sacar provecho del fallo de seguridad.

Origen de las Vulnerabilidades

Errores de programación



A veces, las vulnerabilidades son causadas por simples errores de programación. Por ejemplo, un programador podría olvidarse de verificar correctamente la longitud de la entrada del usuario antes de usarla en un programa, lo que podría crear una vulnerabilidad de desbordamiento del búfer.



Defectos de diseño

En algunos casos, las vulnerabilidades son causadas por fallas de diseño en el sistema operativo o la aplicación. Por ejemplo, un sistema operativo podría permitir a los usuarios ejecutar código con demasiados privilegios, lo que podría crear una vulnerabilidad de escalada de privilegios.

Origen de las Vulnerabilidades

Mala configuración



La mala configuración del sistema operativo o de la aplicación también puede provocar vulnerabilidades. Un ejemplo común es cuando un administrador desactiva accidentalmente una función de seguridad, lo que podría hacer que el sistema sea más vulnerable a ataques.



Código heredado

Un código escrito hace muchos años, llamado código heredado, suele ser una fuente de vulnerabilidades. ¿Por qué? Es posible que el código heredado no haya sido diseñado teniendo en cuenta la seguridad y puede resultar difícil o imposible actualizarlo para abordar las amenazas de seguridad modernas.

Ejemplos de ataques a vulnerabilidades de sistemas operativos

```
.promise().then(function() {  
    [2][2].lock), e[f[0]] = function()  
    == d || a && n.isFunction(a).then()  
    Array(d), k = new Array(10).fill()  
    return n.ready.promise().then()  
    .then(function() {  
        n(d).triggerHandler('ready')  
    })  
    function K() {  
        (d.addEventListeners)  
        Event("onload", K);  
        var c = n(1);  
        break; l.ownFirst();  
        order: 0; width: 0; height: 0;  
        (c.style.zoom = 1)), c.remove()  
        == c ? !1 : !b || b !== !0 && a.get()  
        == c ? !0 : "false" == c ? !1 : "true"
```

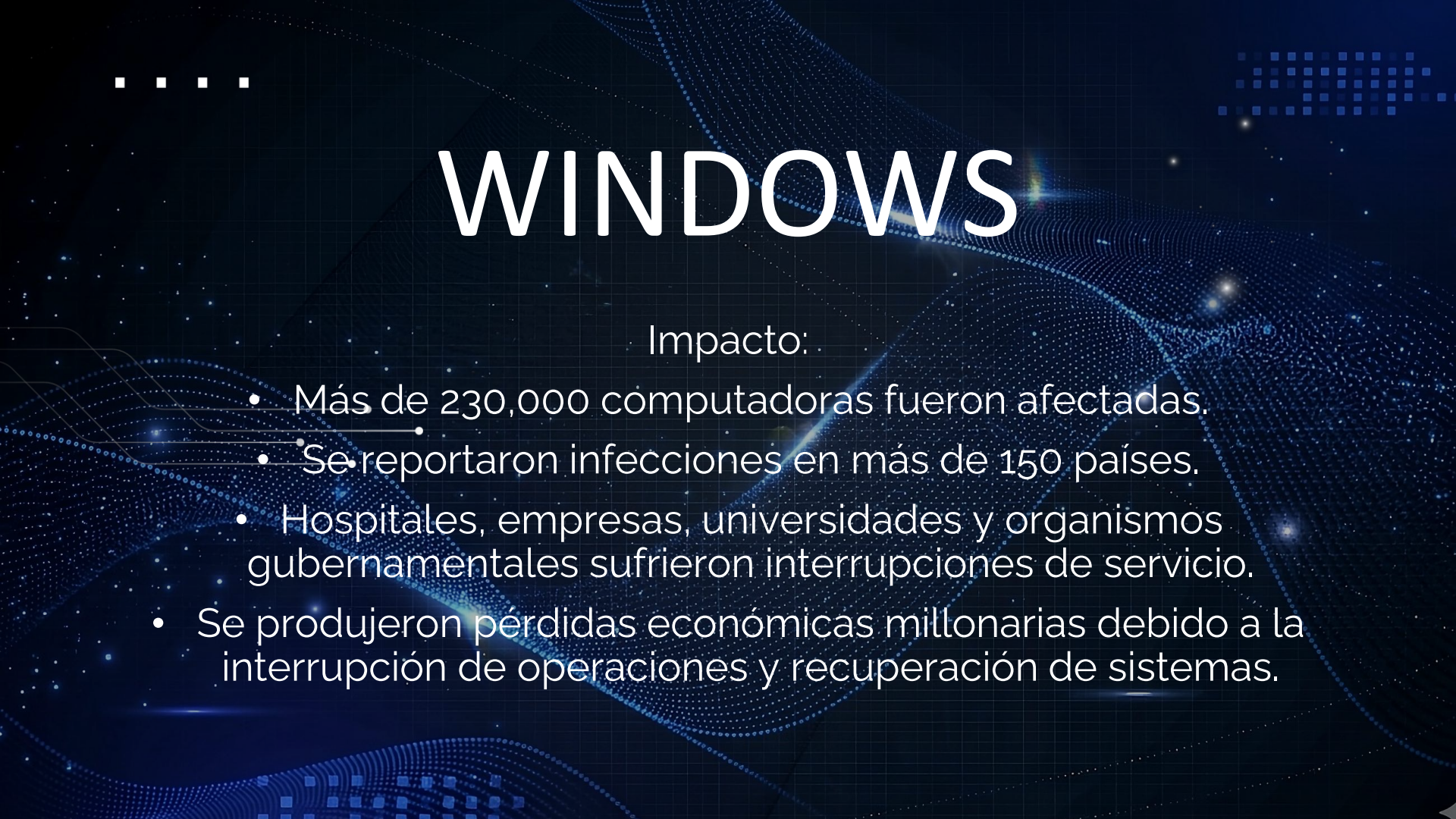


WINDOWS

WINDOWS

El 12 de mayo de 2017, WannaCry comenzó a propagarse rápidamente por Internet utilizando el exploit conocido como EternalBlue. Una vez infectado un equipo, el malware cifraba los archivos del usuario y exigía un pago en Bitcoin para recuperarlos. Además, se propagaba automáticamente a otros equipos vulnerables de la misma red





WINDOWS

Impacto:

- Más de 230,000 computadoras fueron afectadas.
- Se reportaron infecciones en más de 150 países.
- Hospitales, empresas, universidades y organismos gubernamentales sufrieron interrupciones de servicio.
- Se produjeron pérdidas económicas millonarias debido a la interrupción de operaciones y recuperación de sistemas.

The background is a dark blue field with a fine grid pattern. Overlaid on this are several wavy, translucent blue lines that create a sense of depth and movement. These lines are composed of many small dots or particles. There are also some bright, out-of-focus light spots scattered throughout the scene, particularly along the wavy lines. In the top right corner, there is a small cluster of blue squares arranged in a grid-like pattern. In the bottom left corner, there are some thin, white, curved lines that resemble circuit traces or data paths.

Mac OS

Mac OS

Bypass de Gatekeeper (CVE-2021-30657)

Gatekeeper es el guardia de seguridad de tu Mac, este revisa cada aplicación que intentas abrir y bloquea las que no tienen una "credencial" válida.

Qué ocurrió: En 2021 se descubrió que un atacante podía diseñar una aplicación disfrazada que engañaba a Gatekeeper. El sistema la aceptaba como segura, aunque en realidad contenía código malicioso, esto permitía que el malware se ejecutara sin que el usuario recibiera ninguna advertencia.

Ejemplo cotidiano: Es como si alguien entrara a un edificio mostrando una credencial falsa y el guardia lo dejara pasar sin verificarla. Una vez dentro, esa persona podía moverse libremente y causar daños.

Mac OS

Error de escritura fuera de límites (CVE-2022-22675)

El kernel es el "cerebro" del sistema operativo, controla cómo se comunican el hardware y el software.

Qué ocurrió: En macOS Monterey, un fallo permitía que un programa escribiera datos en zonas de la memoria que no le correspondían (*out-of-bounds write*).

Impacto: Un atacante podía aprovechar este error para ejecutar código con privilegios de administrador, tomando control total del sistema.



LINUX

CVE-2022-26134

Minería de criptomonedas

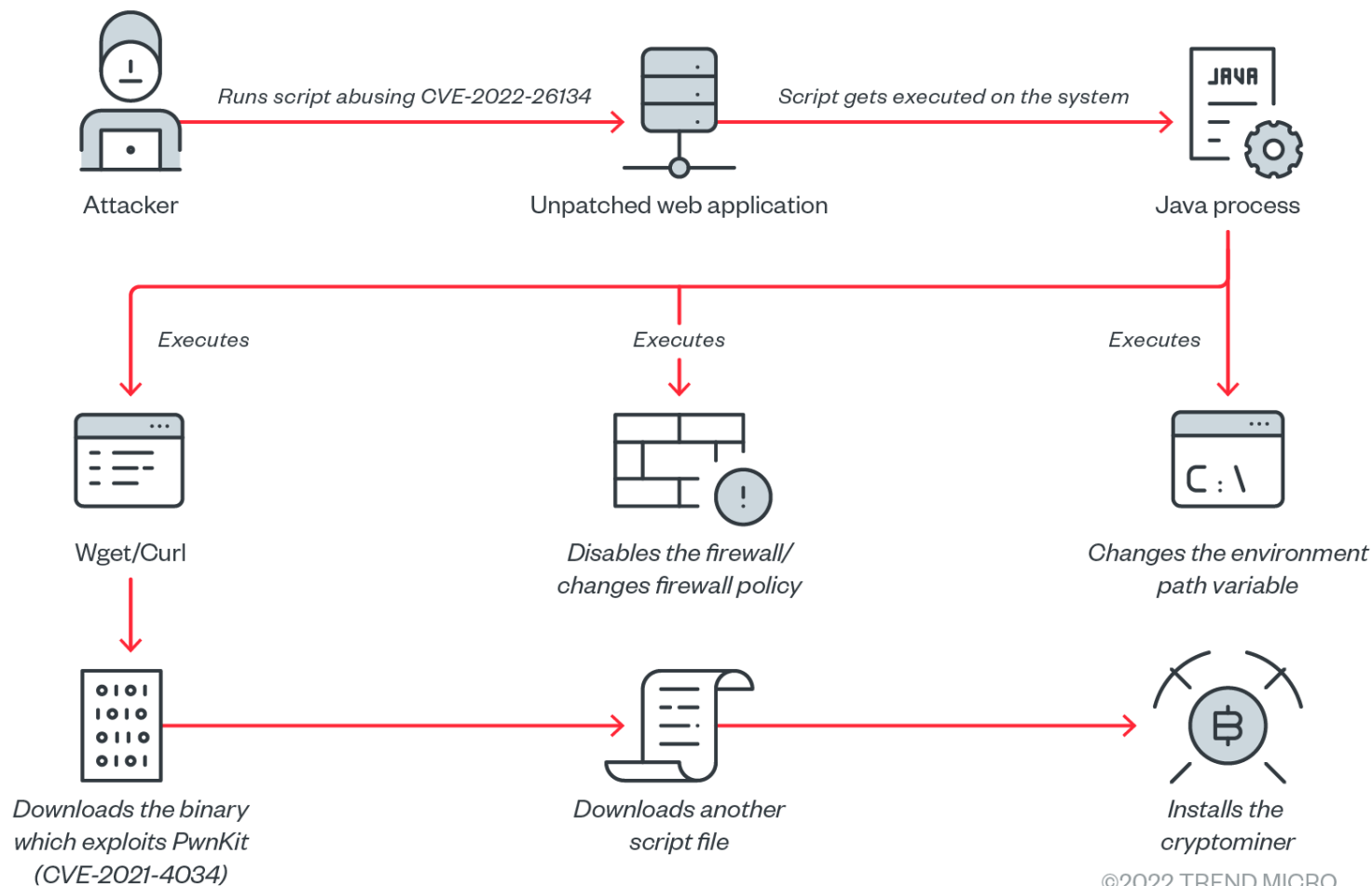


El 2 de junio de 2022, Atlassian publicó un aviso de seguridad CVE-2022-26134, una vulnerabilidad crítica de ejecución remota de código no autenticado en Confluence Server y Confluence Data Center.

Es una vulnerabilidad de inyección OGNL remota y no autenticada que resulta en la ejecución de código en el contexto del servidor Confluence (normalmente el usuario de Confluence en instalaciones de Linux)

OGNL son las siglas en inglés de *Object-Graph Navigation Language* (Lenguaje de Navegación de Grafos de Objetos). Es un lenguaje muy potente y de código abierto utilizado en entornos Java para leer, escribir y manipular las propiedades de los objetos de manera dinámica.





Mitigación de las Vulnerabilidades

1. Identificación de Debilidades

El primer paso para proteger una red consiste en descubrir qué elementos la componen y dónde están sus fallas. Esto se logra mediante:

- **Escaneos de descubrimiento:** Herramientas que catalogan los dispositivos conectados, identifican sus sistemas operativos y verifican los puertos abiertos.
- **Evaluación de riesgos:** Un análisis que permite comprender las brechas existentes en los controles de seguridad actuales.
- **Bases de datos de vulnerabilidades:** Repositorios que recopilan y comparten información sobre fallas ya conocidas en el sector.

2. Priorización Basada en el Riesgo

Debido a que no todas las amenazas representan el mismo peligro, se deben utilizar los datos de las evaluaciones para determinar qué riesgos requieren atención inmediata y cuáles pueden ser postergados o pasados a un segundo plano.

Mitigación de las Vulnerabilidades

3. Implementación de Controles de Seguridad

Una vez priorizados los riesgos, se aplican medidas de mitigación basadas en marcos de ciberseguridad probados y específicos de cada industria. Estos controles internos (preventivos, correctivos y de detección) se clasifican en:

- **De acceso:** Restricciones físicas a los edificios o instalaciones de la organización.
- **Procedimentales:** Capacitación y educación del personal para asegurar el cumplimiento de las normas de seguridad.
- **Técnicos:** Uso de tecnologías como firewalls, autenticación multifactor (MFA) y defensas de seguridad para dispositivos finales (*endpoints*).
- **De cumplimiento:** Adopción de leyes de privacidad y estándares de ciberseguridad para establecer las mejores prácticas.

Mitigación de las Vulnerabilidades

4. Plan de Gestión de Parches

Los proveedores de software lanzan actualizaciones de seguridad de manera regular, pero el éxito de estas depende de su instalación oportuna. Es fundamental programar el tiempo del personal técnico de acuerdo con los calendarios de lanzamiento de los proveedores para instalar los parches de inmediato y evitar posibles ciberataques.

5. Monitoreo Continuo

La mitigación efectiva exige una postura proactiva mediante la supervisión constante de los sistemas y redes. La detección de amenazas en tiempo real permite al equipo de TI responder con mayor rapidez, lo cual se complementa con escaneos periódicos, revisión constante de parches y una gestión de cambios continua.

Referencias

Spektor, H. (2024, October 28). Operating System Vulnerabilities: Understanding and Mitigating the risk. Sternum IoT. <https://sternumiot.com/iot-blog/operating-system-vulnerabilities-understanding-and-mitigating-the-risk/>

OWASP Foundation. (2025). Vulnerabilities. <https://owasp.org/www-community/vulnerabilities/>

Cybersecurity and Infrastructure Security Agency. (2026). Known Exploited Vulnerabilities Catalog. <https://www.cisa.gov/known-exploited-vulnerabilities-catalog>

National Institute of Standards and Technology. (2025). National Vulnerability Database (NVD). <https://nvd.nist.gov/>

Li, J. (2020). Vulnerabilities Mapping Based on OWASP-SANS: A Survey for Static Application Security Testing (SAST). <https://doi.org/10.48550/arXiv.2004.03216>

¿Qué es una vulnerabilidad Zero Day? (n.d.). Ciudadanía | INCIBE. <https://www.incibe.es/ciudadania/blog/que-es-una-vulnerabilidad-zero-day>

Fakterman, T., Erlich, C., & Dahan, A. (2024, February 22). Intruders in the Library: Exploring DLL hijacking. Unit 42. <https://unit42.paloaltonetworks.com/dll-hijacking-techniques/>

Cross-site scripting (XSS) | UNAM-CERT. (n.d.). <https://www.seguridad.unam.mx/cross-site-scripting-xss>

Trend Micro. (2022, September 21). Atlassian Confluence vulnerability CVE-2022-26134 abused for cryptocurrency mining, other malware. https://www.trendmicro.com/en_us/research/22/i/atlassian-confluence-vulnerability-cve-2022-26134-abused-for-cryptocurrency-mining-other-malware.html